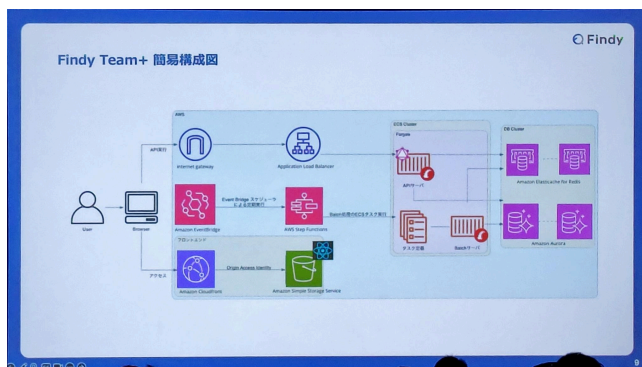


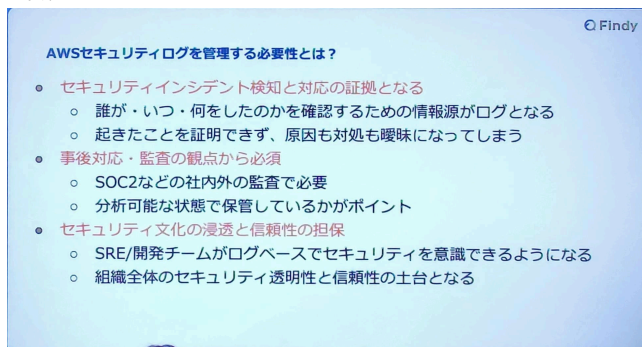
Findy

2025年6月26日 12:43

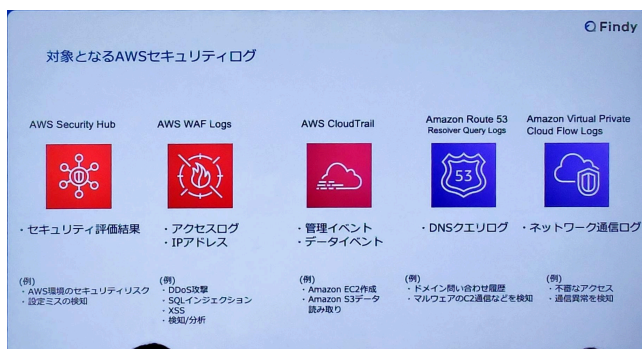


国際セキュリティ認証 SOC2取得

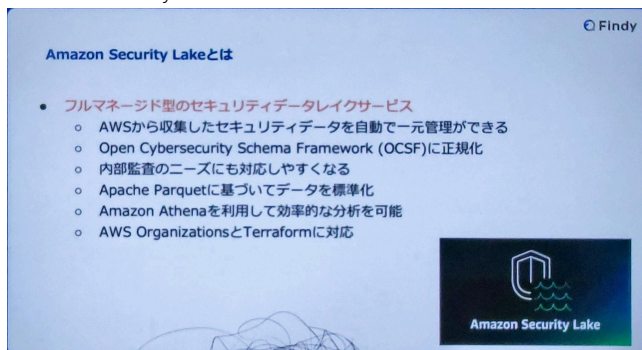
必要性



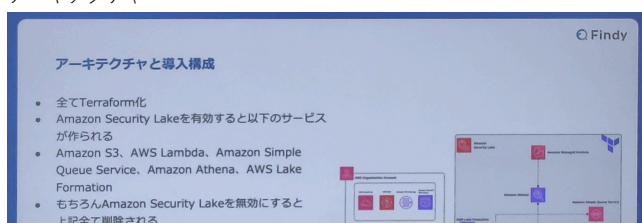
分析可能な状態で保管しているかがポイント

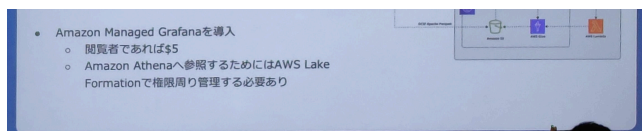


マルチアカウントのセキュリティログを管理するのは大変
→AmazonSecurityLake



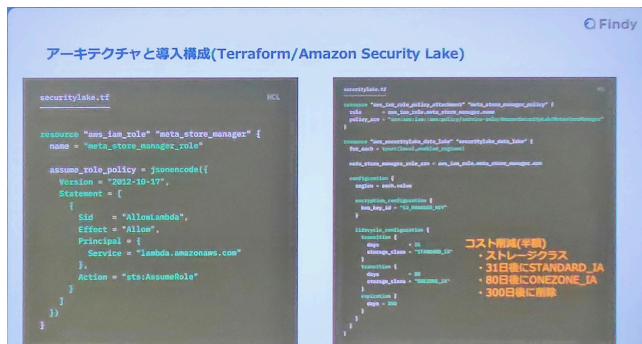
アーキテクチャ





コスト削減

日数でストレージクラスを変更する

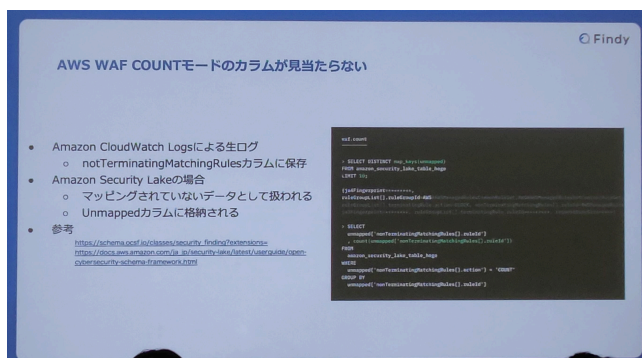
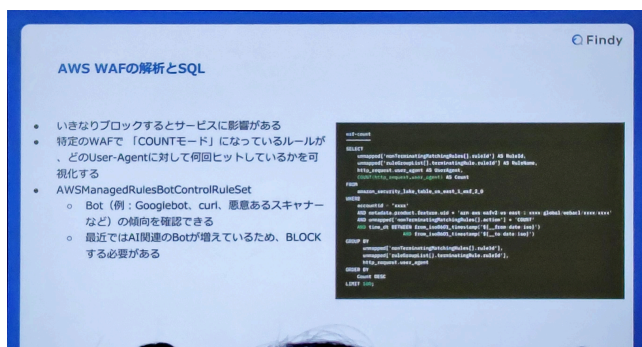
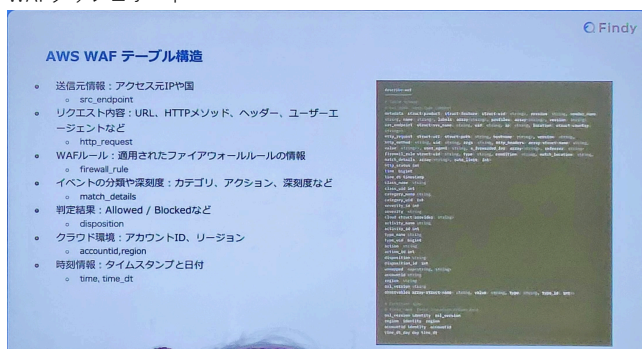


GrafanaはAthena、Guru、S3への権限が必要

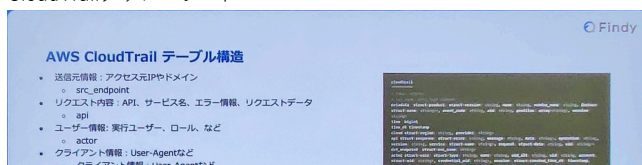
ダッシュボードの作成

Athena上でどのようなテーブル構造になっているか把握しておくことが大事

WAFダッシュボード



CloudTrailダッシュボード



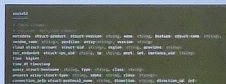
- ・操作対称リソース：操作対象リソース（ARNなど）
 - o resources
- ・イベントの分類や深刻度：カテゴリ、アクション名、深刻度など
 - o class_name, category_name, severity, activity_name
- ・原因経路：イベントステップスやエラー判定（成功/失敗など）
 - o status, api_response, error
- ・クラウド連携：アカウントID、リージョン
 - o account_id, region, cloud_provider
- ・時刻情報：UNIXタイムとタイムスタンプ形式
 - o time, time_dt

- **AWS CloudTrail**
 - Total Event Count (全イベント数)
 - Total Errors (エラー数)
 - Event History (イベント履歴)
 - Top Event Names (イベント名上位)
 - Total Event Sources (イベント発生元)
 - Top Users (ユーザー上位)
 - Total Source IP (IP発生元アドレス)
 - Amazon S3 Access Denied (S3アクセス拒否件数)
 - Amazon EC2 Change Event Count (EC2の設置変更回数)
 - Amazon VPC Change Event Count (VPCの設置変更回数)
 - Security Group Change Event Count (SGの設置変更回数)
 - Error Event Count (エラーイベント)

Route53

Amazon Route 53(Resolver Query Logs) テーブル構造

- DNSエクスプローラ情報
 - query.hostname: クエリ対象のドメイン名 (例: api.example.com)
 - query.type: クエリタイプ (例: A, AAAA, MX など)
 - query.class: クエリクラス (通常 IN)
- 応答情報
 - answers: DNS応答の記録 (タイプ、IPアドレスなど)
- 通信情報
 - src_endpoint.ip: クエリ送信元のIPアドレス
 - src_endpoint.vpc_id: 送信元のVPC ID
 - src_endpoint.private_ip_address: 送信元IPアドレス
 - dst_endpoint_instance_uid: クエリ先のEC2インスタンスID (もしあれば)
- 接続情報
 - connection_info.protocol_name: 通信プロトコル (例: UDP, TCP)
 - connection_info.direction: 通信方向 (例: INBOUND, OUTBOUND)
- イベント情報
 - severity: 深刻度 (Low, Medium, High など)
- DNS応答コードと判定
 - rcode: 応答コード (例: NoError, NXDOMAIN)



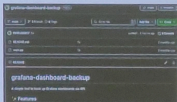
- 不審な操作やアクティビティの検出
 - NXDOMAIN (存在しないドメイン) 発生件数の増減
 - xyz.yz など怪しいドメインのクエリ件数
 - 不審なIPやドメインから特定の怪しいIPにアクセスするクエリ件数
- アクセス傾向の把握
 - 時間帯別クエリ件数の推移 (ピーク時間帯分析)
 - クエリが多い上位ドメインランキング
 - 多くクエリを送っている接続元IP / IPのランキング
- 名前解決成功/失敗率
 - 応答コード (rcode) 別の件数グラフ
 - NoError / NXDOMAIN / SERVFAIL などの割合
 - 成功率 = NoError件数 / 総件数 を日次/週次でトレンド化
- 判定結果・アクションごとの可視化
 - disposition (Allowed / Blocked) の割合と推移
 - Reason (Allow / Block) の割合と推移
- セキュリティインシデントのヒント
 - 通常見られないドメインへの急激なアクセス増加

Grafana

運用とベストプラクティス

- Amazon Managed Grafanaの管理方法
 - Terraform化
 - SSOユーザー管理
 - Grafana Alert
 - Dashboardは手動管理
 - 7000ファイルのGrafanaを管理することはほぼ不可能に近い
 - CDで隔週バックアップを取得し、差分チェックを行うことにした
 - grafana-dashboards-backup
 - Goで開発
 - ↳ <https://github.com/RVIRUS0817/grafana-dashboards-backup>





ダッシュボードのバックアップはGoで開発

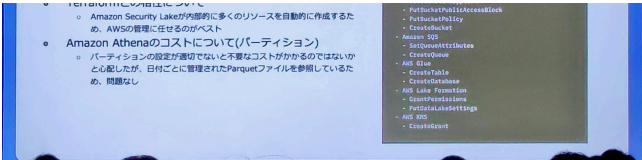
SecurityLakeの場合、個別にVPCFlowLogやWAFのログを有効化しなくて良い
Athenaの料金は安い

疑問点

- Amazon VPC Flow LogやAWS WAFのログを個別に有効化していないにも関わらず、なぜ取得できているのか？
- AWS内網でログを取得するためのストリームがあり、データを取り込んでいる
- これらのログを個別に有効化した場合に料金が二重に発生するのではないのか？
- そのうちこのことは基本的なこと

 Findy





Bedrock

